

Política de Resposta a Incidentes

Processo para identificar, conter, comunicar, corrigir e aprender com incidentes de segurança, privacidade e serviços financeiros.

Código	NRX-SEC-INC-001	Versão	1.0
Responsável	Jhonatan Gasperi de Oliveira	Vigência	01 de julho de 2026
Classificação	Uso controlado	Próxima revisão	01 de julho de 2027

VIGENTE

Documento aprovado para uso interno e apresentação como evidência institucional, sujeito às revisões e controles descritos.

1. Objetivo

Definir uma resposta coordenada e rastreável para incidentes que afetem confidencialidade, integridade, disponibilidade, autenticação, serviços financeiros, dados pessoais ou dados clínicos tratados pela NeuroNex AI.

2. Escopo

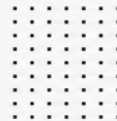
Abrange aplicação, banco de dados, autenticação, Edge Functions, GitHub, Vercel, Supabase, Cloudflare/R2, Asaas BaaS, integrações Google, provedores de IA, suporte e dispositivos administrativos.

3. Classificação de severidade

Severidade	Exemplos	Resposta mínima
Crítico	Exposição de credencial; operação financeira não autorizada; acesso indevido a dados clínicos; comprometimento de webhook; indisponibilidade crítica financeira.	Resposta imediata; contenção prioritária; comunicação executiva e contratual.
Alto	Vulnerabilidade explorável em produção; perda de logs; acesso privilegiado anormal; vazamento limitado de dados pessoais.	Início imediato; plano de correção em até 24 horas.
Médio	Impacto limitado, sem exploração confirmada, com controles compensatórios disponíveis.	Tratamento priorizado e prazo definido.
Baixo	Evento sem impacto material ou já contido, com baixa probabilidade de recorrência.	Registro, correção programada e acompanhamento.

4. Responsabilidades

Papel	Responsabilidade
Responsável institucional	Coordenar a resposta, aprovar contenção, decidir comunicações, preservar evidências e encerrar o incidente.
Operação técnica	Coletar logs, aplicar bloqueios, restaurar serviços e validar a correção sem expor dados sensíveis.
Suporte	Receber relatos, registrar contexto mínimo, não solicitar secrets e encaminhar incidentes financeiros ao Asaas.



Papel	Responsabilidade
Fornecedores	Atuar conforme contratos, SLAs, canais de segurança e obrigações de notificação.

5. Processo de resposta

- Detecção e registro: criar ID, registrar data/hora, origem, sistemas, sintomas e responsável.
- Triagem e classificação: confirmar escopo preliminar, severidade, impacto potencial e relação com o Asaas.
- Preservação: guardar logs e evidências sanitizadas, evitando alteração desnecessária ou exposição de conteúdo clínico.
- Contenção: revogar sessões, rotacionar secrets, bloquear endpoint, pausar operação ou desabilitar funcionalidade, conforme o risco.
- Eradicação: remover a causa, corrigir vulnerabilidade, ajustar política, código, configuração ou credencial.
- Recuperação: restaurar o serviço de forma controlada, executar testes e intensificar monitoramento temporário.
- Comunicação: informar partes obrigatórias nos prazos aplicáveis.
- Encerramento: registrar causa raiz, impacto, ações corretivas, prevenção de recorrência e aprovação final.

6. Comunicação

- Incidentes relevantes aos serviços financeiros contratados devem ser comunicados ao Asaas imediatamente e, no máximo, em até 24 horas após a identificação.
- Clientes e usuários devem receber comunicação clara quando necessária para proteção, continuidade ou cumprimento de obrigação legal.
- Comunicações à ANPD e aos titulares serão avaliadas conforme natureza, risco e exigências legais aplicáveis.
- Nenhuma comunicação deve revelar secrets, dados clínicos desnecessários ou detalhes que aumentem o risco de exploração.

7. Preservação de evidências

- Registrar horários em fuso consistente e identificar a fonte do log.
- Guardar cópias sanitizadas, hashes e referências de artefatos quando possível.
- Restringir o acesso às evidências ao responsável e às partes estritamente necessárias.
- Não utilizar prints com tokens, credenciais, dados de cartão ou conteúdo clínico identificável.

8. Pós-incidente e prevenção de recorrência

Todo incidente crítico ou alto deve gerar análise de causa raiz, plano corretivo, responsável, prazo, risco residual e validação. Incidentes repetidos devem motivar revisão de arquitetura, fornecedores, políticas, treinamento ou controles automatizados.

9. Testes e manutenção

O procedimento deve ser testado por exercício de mesa ao menos uma vez por ano e após mudança material. O primeiro cenário recomendado é suspeita de vazamento de credencial Asaas, com contenção, rotação, preservação de logs e comunicação em até 24 horas.

10. Registros obrigatórios

ID do incidente, detecção, reportante, severidade, sistemas, dados potencialmente afetados, relevância Asaas, contenção, notificações, recuperação, causa raiz, ações corretivas e aprovação de encerramento.



Aprovação

Aprovo este documento e determino sua aplicação a partir da data de vigência indicada.

Jhonatan Gasperi de Oliveira

Responsável e aprovador institucional

Assinatura digital: _____ Data: 01/07/2026